

Movimentação Lateral em Active Directory — Introdução

Pular para a Investigação Prática: [Aperte aqui](#)

Contexto

Em ambientes de Active Directory (AD) com muitas vulnerabilidades, atacantes que comprometem uma única conta raramente se limitam a ela. Eles utilizam protocolos nativos do ambiente — como **SMB** e **RDP** — para migrar do ponto de apoio inicial em direção aos servidores que concentram os ativos mais críticos, como:

- Controladores de domínio
- Servidores de arquivos
- Bancos de dados

A principal dificuldade para os defensores é que esses são os **mesmos protocolos utilizados diariamente pelos administradores**, o que torna a distinção entre tráfego legítimo e malicioso mais complexa.

Sobre esta atividade

Esta sala aborda **três técnicas de movimentação lateral** e os artefatos de log gerados por cada uma delas. A abordagem segue duas etapas:

1. Análise do tráfego **normal** de cada protocolo, para estabelecer uma linha de base.
2. Investigação de um **ataque simulado**, que utiliza SMB, PsExec e RDP para se mover de uma estação de trabalho comprometida até o Controlador de Domínio.

Objetivos de Aprendizagem

- Detectar comandos de descoberta do AD por meio da criação de processos e registros de **PowerShell Script Block Logging**.
- Identificar movimentação lateral via SMB por meio de padrões de acesso a compartilhamentos administrativos.
- Identificar o uso do **PsExec** através de artefatos de instalação de serviço, criação de *named pipes* e correlação de eventos entre origem e destino.
- Detectar movimentação lateral baseada em RDP utilizando o **Logon Type 10**, rastreando cadeias de múltiplos saltos por meio da correlação de IDs de logon e artefatos de processo.
- Correlacionar artefatos entre sistemas de origem e destino para reconstruir o caminho percorrido por um invasor.

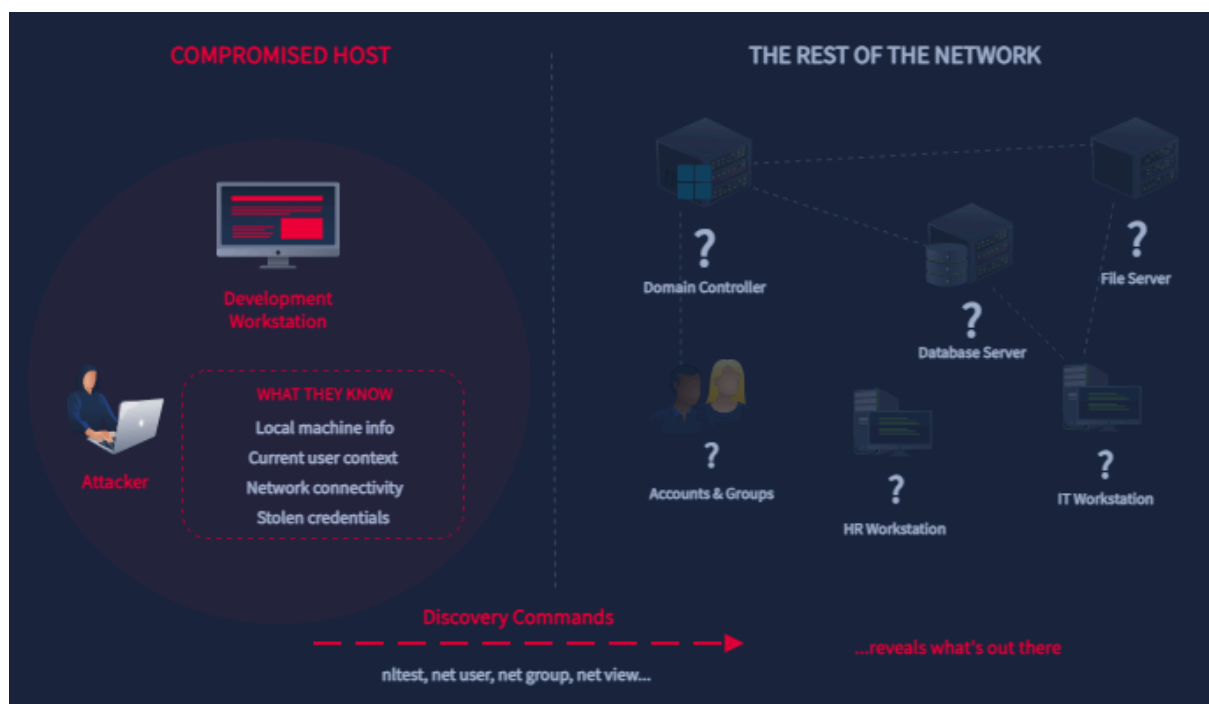
O que foi realizado

Nesta etapa inicial, foi apresentado o contexto da atividade: como os atacantes exploram protocolos legítimos do Active Directory (SMB e RDP) para se movimentar lateralmente dentro da rede após um comprometimento inicial. Também foram definidos os objetivos de aprendizagem que guiarão a investigação prática, com foco em três técnicas — **SMB**, **PsExec** e **RDP** — e nos artefatos de log correspondentes a cada uma, essenciais para a correlação de eventos entre estações de trabalho e servidores críticos, como o Controlador de Domínio.

Descoberta e Reconhecimento em Active Directory

Visão Geral

Antes de qualquer movimentação lateral, o invasor precisa entender o ambiente em que está inserido. Ao obter o primeiro acesso a uma rede, ele desconhece a topologia, os servidores existentes e quais contas possuem privilégios elevados. Por isso, a etapa inicial de um ataque é sempre a **descoberta**: um conjunto de comandos usados para mapear o Active Directory (AD) e planejar os próximos passos.



Esta etapa é focada especificamente na **descoberta de AD** — consultas que revelam contas de domínio, grupos, relações de confiança e sistemas em rede —, diferente do reconhecimento genérico de host (`systeminfo`, `whoami`), que também ocorre nessa fase mas não fornece o mesmo nível de mapeamento estratégico.

Comandos Utilizados

Categoria	Comando	Informação obtida
-----------	---------	-------------------

Domínio/Confiança	<code>nltest /dclist:dominio</code>	Controladores de domínio
a		
Domínio/Confiança	<code>nltest /domain_trusts</code>	Relações de confiança entre domínios
a		
Contas/Grupos	<code>net user /domain</code>	Contas de usuário do domínio
Contas/Grupos	<code>net group "Domain Admins" /domain</code>	Membros do grupo Administradores de Domínio
Contas/Grupos	<code>net group "Enterprise Admins" /domain</code>	Membros do grupo Administradores Corporativos
Contas/Grupos	<code>net localgroup administrators</code>	Administradores locais da máquina
Sistemas	<code>net view</code>	Máquinas visíveis na rede
Sistemas	<code>net view \\THM-SHR-SRV /all</code>	Compartilhamentos de um host remoto
PowerShell	<code>Get-ADUser -Filter *</code>	Enumeração de usuários via PowerShell
PowerShell	<code>Get-ADGroupMember "Domain Admins"</code>	Membros de grupo via PowerShell
PowerShell	<code>Get-ADComputer -Filter *</code>	Contas de computador do domínio

Um ponto central: **nenhum desses comandos exige privilégios administrativos**. O AD concede acesso de leitura por padrão a qualquer usuário autenticado, o que significa que uma conta comprometida qualquer — mesmo de baixo privilégio — consegue enumerar todo o domínio. Isso não é uma falha de configuração, é o comportamento padrão do AD, e é justamente o que facilita o planejamento de ataques.

Além dos comandos nativos, ferramentas de terceiros como `adfind.exe` (associada a grupos de ransomware como Conti e FIN7), `dsquery` e a classe `.NET [System.DirectoryServices.DirectorySearcher]` também são usadas para consultas LDAP diretas.

Referência real: o grupo **Volt Typhoon**, ligado ao Estado chinês, é documentado pela CISA (Aviso AA24-038A) utilizando fortemente comandos nativos (`net user`, `nltest`, `netsh`, `wmic`) — uma técnica conhecida como **LOTL (Living Off The Land)**. Como são binários legítimos do sistema, não acionam antivírus e se confundem com atividade administrativa normal.

Fontes de Log para Detecção

A descoberta é detectada por duas fontes principais:

- **Sysmon (Evento 1)** — criação de processos; captura comandos CMD/PowerShell na linha de comando.
- **PowerShell (Evento 4104)** — Script Block Logging; registra cmdlets e parâmetros executados.

Detecção via Sysmon

```
index=win EventCode=1
```

```
| search CommandLine IN ("*nltest*", "*net * user*", "*net * group*", "*net * view*", "*net * localgroup*")
```

```
| table _time, host, User, Image, CommandLine, ParentImage
```

```
| sort _time
```

1 index=win EventCode=1

2 | search CommandLine IN ("*nltest*", "*net * user*", "*net * group*", "*net * view*", "*net * localgroup*")

3 | table _time, host, User, Image, CommandLine, ParentImage

4 | sort _time

✓ 12 events (before 9/11/26 7:11:52.000 PM) No Event Sampling ▾

Job ▾ || ▮ → ⌵ ⌴ Smart Mode ▾

Events Patterns **Statistics (12)** Visualization

Show: 20 Per Page ▾  Format ▾  Preview: On

_time ↕	host ↕ 	User ↕ 	Image ↕ 	CommandLine ↕ 	ParentImage ↕ 
2026-03-05 20:53:47	THM-IT-DESK	NOT_TRANSLATED tryhatmestudios\luke.sullivan	C:\Windows\System32\net.exe	net view \\THM-SHR-SRV	C:\Windows\System32\cmd.exe
2026-03-06 03:50:50	THM-MKT-WS	NOT_TRANSLATED tryhatmestudios\michelle.smith	C:\Windows\System32\nltest.exe	nltest /domain_trusts	C:\Windows\System32\cmd.exe
2026-03-06 03:50:56	THM-MKT-WS	NOT_TRANSLATED tryhatmestudios\michelle.smith	C:\Windows\System32\net.exe	net user /domain	C:\Windows\System32\cmd.exe
2026-03-06 03:51:03	THM-MKT-WS	NOT_TRANSLATED tryhatmestudios\michelle.smith	C:\Windows\System32\net.exe	net group "Domain Admins" /domain	C:\Windows\System32\cmd.exe
2026-03-06 03:51:09	THM-MKT-WS	NOT_TRANSLATED tryhatmestudios\michelle.smith	C:\Windows\System32\net.exe	net group "Enterprise Admins" /domain	C:\Windows\System32\cmd.exe
2026-03-06 03:51:15	THM-MKT-WS	NOT_TRANSLATED	C:\Windows\System32\net.exe	net localgroup Administrators	C:\Windows\System32\cmd.exe

Essa consulta expõe **quando, em qual host e por qual usuário** o comando foi executado, além do próprio comando via CommandLine. Comandos de descoberta em estações que não deveriam executá-los é um forte indicativo de atividade maliciosa — sempre lembrando que **contexto é tudo**.

Detecção via PowerShell

```
index=win EventCode=4104
```

```
| search Message IN ("*Get-ADUser*", "*Get-ADGroupMember*", "*Get-ADComputer*")
```

```
| table _time, Message
```

```
| sort _time
```

```

1 index=win EventCode=4104
2 | search Message IN ("*Get-ADUser*", "*Get-ADGroupMember*", "*Get-ADComputer*")
3 | table _time, Message
4 | sort _time

```

✓ 3 events (before 9/11/26 6:46:32.000 PM) No Event Sampling ▾		Job ▾	▮	↗	🖨	⬇
Events	Patterns	Statistics (3)	Visualization			
Show: 20 Per Page ▾ Format ▾ Preview: On						
_time ↕	Message ↕					
2026-03-06 03:52:06	Creating Scriptblock text (1 of 1): Import-Module ActiveDirectory; Get-ADUser -Filter * -Properties MemberOf Select-Object Name, SamAccountName ScriptBlock ID: dd86ce07-6ddd-44d8-b323-e9bad796c0b9 Path:					
2026-03-06 03:52:19	Creating Scriptblock text (1 of 1): Get-ADGroupMember 'Domain Admins' ScriptBlock ID: 6010740e-5867-4efc-9fa5-43e16e4d9f0d Path:					
2026-03-06 03:52:26	Creating Scriptblock text (1 of 1): Get-ADComputer -Filter * Select-Object Name, DNSHostName ScriptBlock ID: 5919e409-9803-4608-b1da-15cc8ba43743 Path:					

O campo **Message** traz o conteúdo completo do bloco de script — cmdlet e parâmetros.

Limitação do Script Block Logging: por gerar grande volume de eventos, muitas organizações o habilitam apenas em ativos críticos ou durante investigações. Na ausência dele, é possível recorrer ao Sysmon Evento 1 ou ao Evento 4688 (Windows Security), mas ambos capturam apenas a inicialização do processo **powershell.exe** — cmdlets executados interativamente dentro de uma sessão já aberta não geram eventos separados. O Script Block Logging resolve isso, pois registra cada comando dentro da sessão.

Evasão via ofuscação: comandos codificados (ex.: PowerShell em Base64 via **-enc**) ainda geram o Evento 1 do Sysmon, porém com a linha de comando ilegível. O Script Block Logging é mais resiliente nesse caso, pois registra o bloco **já decodificado** pelo próprio PowerShell.

Questão Respondida

Qual foi o primeiro comando de descoberta executado pelo atacante?

nltest /domain_trusts

O que foi realizado

Nesta etapa foi analisada a fase de **descoberta** em Active Directory, entendendo sua função no ciclo de ataque: mapear contas, grupos, relações de confiança e sistemas antes da movimentação lateral. Foram identificados os comandos nativos (**nltest**, **net user**, **net group**, **net view**) e cmdlets PowerShell (**Get-ADUser**, **Get-ADGroupMember**, **Get-ADComputer**) mais comuns nessa fase, destacando que todos operam com permissões de usuário comum — uma característica intencional do AD que facilita a ação de invasores.

Foi discutida a técnica **LOTL (Living Off The Land)**, exemplificada pelo grupo **Volt Typhoon**, que evita detecção usando apenas ferramentas nativas do sistema.

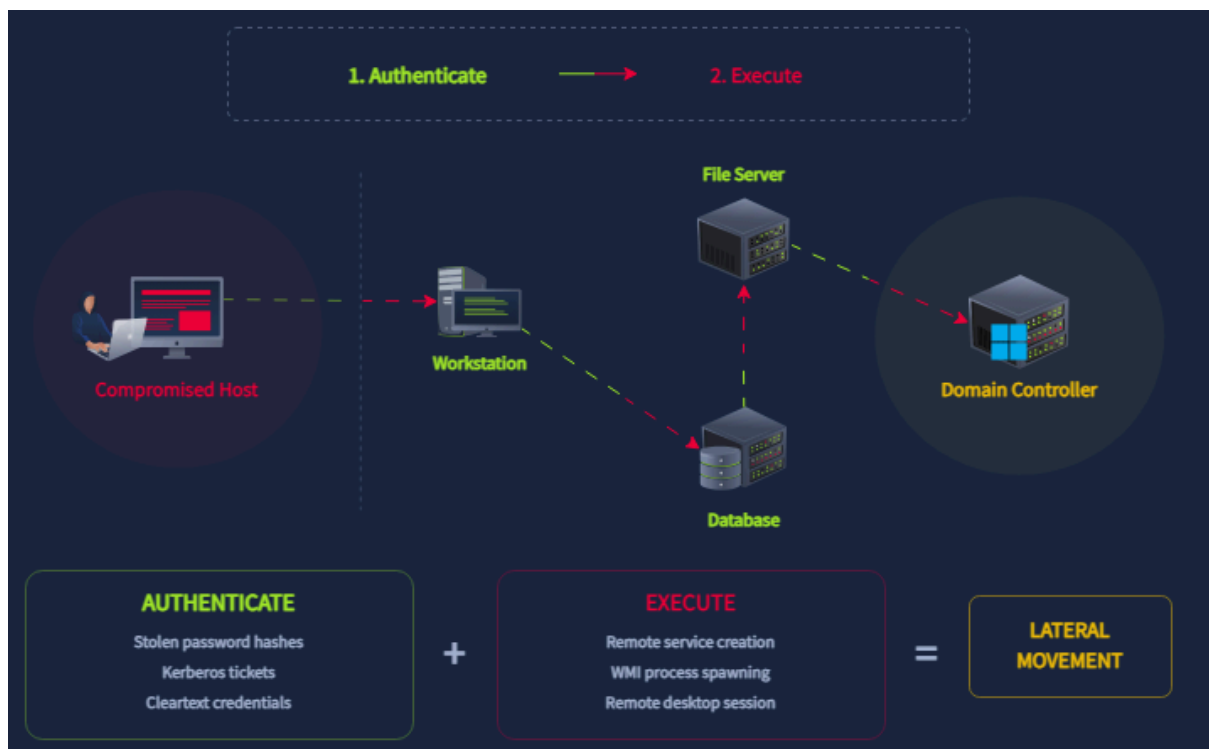
Por fim, foi praticada a detecção dessa atividade no **Splunk**, utilizando duas fontes de log complementares — **Sysmon Evento 1** (criação de processo) e **PowerShell Evento 4104** (Script Block Logging) —, essenciais para correlacionar quem, quando e onde executou determinado comando, e para identificar tentativas de ofuscação por parte do atacante.

Como Funciona o Movimento Lateral

Visão Geral

Após concluir a fase de descoberta, o atacante já sabe quais servidores existem, quais contas possuem direitos administrativos e quais máquinas valem a pena atacar. O próximo passo é se deslocar até esses alvos — seja o Controlador de Domínio, um servidor de banco de dados ou um compartilhamento com dados sensíveis.

Toda técnica de movimentação lateral segue o mesmo padrão: o atacante **se autentica** em uma máquina remota usando credenciais roubadas ou indevidamente utilizadas e, em seguida, **executa** alguma ação nessa máquina. A técnica específica pode variar, mas essa sequência — autenticar e depois executar — está sempre presente.



O Modelo de Origem e Destino

Toda conexão remota gera artefatos em **duas máquinas diferentes**:

- **Origem:** onde o atacante inicia a conexão. Registra quais credenciais foram usadas e qual alvo foi escolhido.
- **Destino:** onde a sessão termina e a ação ocorre. Registra que alguém se conectou e o que essa pessoa fez.

Analisar apenas o destino revela que o ataque ocorreu, mas não necessariamente sua origem. Analisar apenas a origem revela a intenção, mas não se ela foi bem-sucedida. Por isso, a correlação entre os dois lados é essencial.



Logon Type: O Primeiro Ponto de Verificação

Quando alguém se conecta a uma máquina remota, o Windows registra o **Evento 4624** na máquina de destino. O campo **Logon_Type** indica como a conexão foi realizada:

Tipo de Logon	Significado	Protocolo Comum	O que indica
3	Login de rede	SMB, PsExec	Acesso remoto sem sessão interativa
7	Desbloquear/Reconectar	RDP	Reconexão de sessão ou desbloqueio de estação
10	Interativo remoto	RDP	Sessão completa de desktop

O **Tipo 10** é direto, pois sempre indica RDP. Já o **Tipo 3** é mais ambíguo, pois tanto SMB quanto PsExec geram esse tipo de logon — exigindo artefatos adicionais para diferenciá-los (abordados em etapas futuras).

Atenção: se um invasor se conecta via RDP enquanto a mesma conta já possui uma sessão ativa ou desconectada no host, o Windows reconecta à sessão existente em vez de criar uma nova — gerando um logon **Tipo 7** em vez do Tipo 10. Um logon Tipo 7 com um IP remoto (diferente de 127.0.0.1) é um forte indicativo de reconexão via RDP maliciosa, não de desbloqueio físico. Filtrar apenas por **Logon_Type=10** não captura essas reconexões. Além disso,

cada reconexão gera um novo `Logon_ID`, mesmo que a sessão RDP original persista — o que pode quebrar a correlação baseada nesse campo.

Evento 4648: Rastreando a Origem

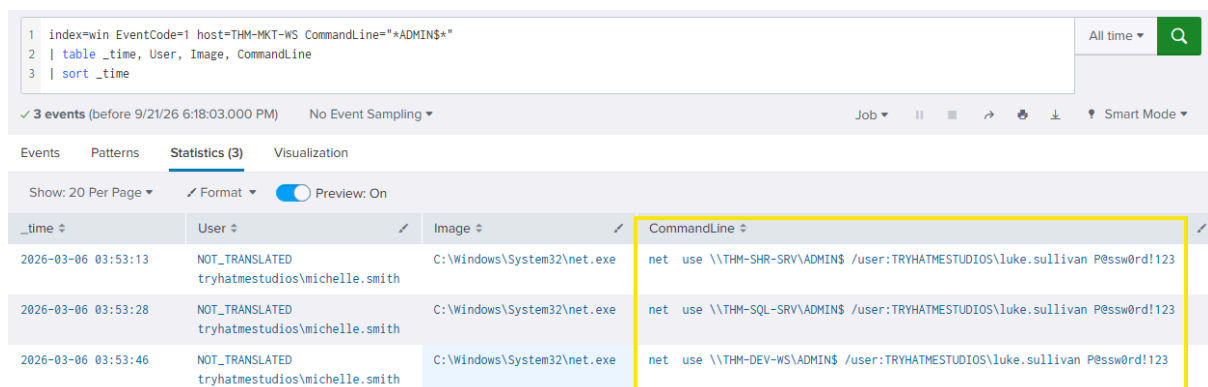
O **Evento 4648** (Logon usando credenciais explícitas) é acionado na máquina de **origem** quando um processo utiliza credenciais diferentes das do usuário atualmente conectado.

Exemplo: se `liam.patel` executa `net use \\THM-SHR-SRV\ADMIN$ /user:luke.sullivan`, o Evento 4648 é registrado em `THM-MKT-WS`, contendo:

- Conta original (`liam.patel`)
- Conta alternativa (`luke.sullivan`)
- Servidor de destino (`THM-SHR-SRV`)

Esse evento revela diretamente qual máquina iniciou a conexão e quais credenciais foram usadas — algo que a maioria dos registros do lado do destino não mostra, já que eles apenas indicam quem se conectou, não quem estava operando o teclado no momento.

O **Evento 1 do Sysmon** (Criação de Processo) complementa essa informação, capturando o processo `net.exe` com a linha de comando completa — incluindo servidor de destino, conta especificada no parâmetro `/user:` e a senha.



_time	User	Image	CommandLine
2026-03-06 03:53:13	NOT_TRANSLATED tryhatmestudios\michelle.smith	C:\Windows\System32\net.exe	net use \\THM-SHR-SRV\ADMIN\$ /user:TRYHATMESTUDIOS\luke.sullivan P@ssw0rd!123
2026-03-06 03:53:28	NOT_TRANSLATED tryhatmestudios\michelle.smith	C:\Windows\System32\net.exe	net use \\THM-SQL-SRV\ADMIN\$ /user:TRYHATMESTUDIOS\luke.sullivan P@ssw0rd!123
2026-03-06 03:53:46	NOT_TRANSLATED tryhatmestudios\michelle.smith	C:\Windows\System32\net.exe	net use \\THM-DEV-WS\ADMIN\$ /user:TRYHATMESTUDIOS\luke.sullivan P@ssw0rd!123

Juntos, esses dois eventos do lado da origem fornecem contexto mais completo sobre a mesma atividade.

Aviso: o Evento 4648 só é acionado quando as credenciais são fornecidas **explicitamente** — como em `net use /user:`, `runas` ou ao digitar credenciais em uma caixa de diálogo RDP. Ele **não** é acionado em técnicas como Pass-the-Hash, Pass-the-Ticket ou autenticação Kerberos SSO, pois essas reutilizam credenciais em cache sem fornecê-las explicitamente.

Normal vs. Suspeito: Mesmos Eventos, Contextos Diferentes

Uma sessão administrativa legítima e uma movimentação lateral maliciosa geram os **mesmos IDs de evento** — ambos podem gerar o Evento 4624 e o Evento 4648, e ambos

representam "autenticação bem-sucedida em host remoto". O que diferencia um do outro é o **contexto**:

Fator	Provavelmente legítimo	Vale a pena investigar
Fonte	Estação de administrador de TI	Estação de marketing
Conta	Administrador de TI	Usuário comum acessando compartilhamentos administrativos
Horário	Horário comercial	Madrugada de fim de semana
Alvo	Servidores geridos normalmente pelo admin	Conexões entre estações de trabalho
Padrão	Sessão sustentada em um único servidor	Conexões rápidas a múltiplos servidores

Por Que o Movimento Lateral Funciona

Na prática, funciona principalmente por configurações incorretas comuns no ambiente:

- **Reutilização de senhas** em contas de administrador local (o Microsoft LAPS foi criado justamente para mitigar isso).
- Contas administrativas compartilhadas.
- Adesões a grupos excessivamente permissivas.
- Segmentação de rede deficiente entre hosts.
- RDP habilitado em máquinas que não precisam dele, ampliando a superfície de ataque.

Uma única credencial comprometida pode, nessas condições, desbloquear toda a rede. Por isso, detecção e *hardening* do ambiente (limitando onde credenciais podem ser usadas) são igualmente importantes.

Questões Respondidas

Qual tipo de logon no Evento 4624 indica uma sessão de área de trabalho remota?

Resposta: **10**

Qual é o ID de evento, registrado no sistema de origem, quando um processo usa credenciais alternativas para se conectar a um recurso remoto?

Resposta: **4648**

O que foi realizado

Nesta etapa foi compreendido o funcionamento estrutural da movimentação lateral: o padrão universal de **autenticar e depois executar**, e o **modelo de origem e destino**, no

qual cada conexão remota gera artefatos distintos em duas máquinas — essenciais para reconstruir o caminho completo de um ataque.

Foi analisado o campo **Logon_Type** do **Evento 4624**, destacando os tipos 3 (SMB/PsExec), 7 (reconexão/desbloqueio) e 10 (RDP interativo), incluindo a armadilha de reconexões RDP sendo registradas como Tipo 7.

Foi estudado o **Evento 4648**, essencial para rastrear a origem de uma conexão quando credenciais explícitas são usadas, complementado pelo **Evento 1 do Sysmon**, que expõe a linha de comando completa do processo de conexão.

Por fim, foi reforçado que a diferenciação entre atividade legítima e maliciosa depende do **contexto** (origem, conta, horário, alvo e padrão de conexão), e que a movimentação lateral só é viável na prática devido a falhas comuns de configuração, como reutilização de senhas administrativas e segmentação de rede deficiente.

Detecção de Movimentação Lateral via SMB

Por que o SMB é o protocolo preferido dos atacantes

Ao estudar esta etapa, entendi que o **SMB** é o protocolo mais utilizado em movimentação lateral justamente por ser o mais comum e o mais "barulhento" dentro de uma rede corporativa. Mapear uma unidade de rede, abrir um documento compartilhado, imprimir em uma impressora de rede, aplicar políticas de grupo ou rodar agentes de backup — tudo isso gera tráfego SMB legítimo e constante.

Essa abundância de atividade legítima é exatamente o que torna o protocolo atraente para invasores: uma conexão maliciosa tem grandes chances de se perder no meio do ruído do dia a dia.

Compartilhamentos Administrativos

Compreendi que sistemas Windows criam automaticamente, através do serviço *Servidor*, um conjunto de **compartilhamentos administrativos padrão**, acessíveis via SMB na **porta 445**:

Compartilhamento	Aponta para
C\$	Raiz da unidade do sistema (demais unidades seguem o mesmo padrão: D\$, E\$...)
ADMIN\$	%SystemRoot%, normalmente C:\Windows
IPC\$	Compartilhamento lógico para comunicação entre processos via <i>named pipes</i> , essencial para chamadas RPC remotas

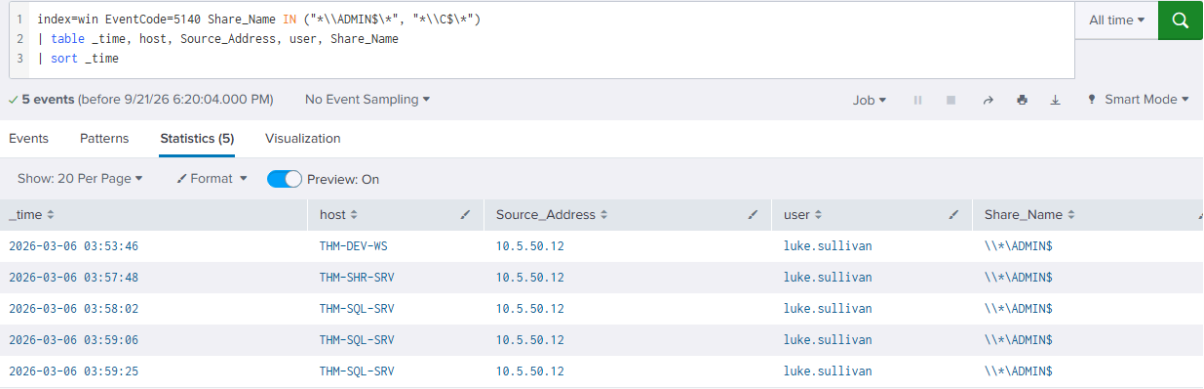
O ponto que considero mais importante aqui é o **comportamental**: usuários comuns não acessam esses compartilhamentos durante o trabalho normal — eles utilizam compartilhamentos nomeados, como *Marketing*, *Compartilhado* ou *TI*. Portanto, quando um acesso a compartilhamento administrativo aparece nos logs, só existem duas possibilidades: um administrador executando manutenção, ou um atacante se movimentando lateralmente.

O acesso a esses compartilhamentos normalmente aciona dois eventos:

- **Evento 5140** — Um objeto de compartilhamento de rede foi acessado
- **Evento 4624** — Uma conta foi conectada com sucesso

Caso real: Earth Kurma

O grupo APT **Earth Kurma**, documentado pela Trend Micro em 2025, utilizou amplamente compartilhamentos administrativos em campanhas contra redes governamentais do Sudeste Asiático. O fluxo era: autenticação com credenciais roubadas por malware, cópia de arquivos via `net use \\target\c$` e criação de serviços remotos com `sc` para executar as cargas úteis — tudo usando apenas ferramentas nativas do Windows e SMB.



The screenshot shows a SIEM interface with a search bar at the top containing the query: `index=win EventCode=5140 Share_Name IN ("*\\ADMIN$*", "*\\C$*")`. Below the search bar, there are tabs for 'Events', 'Patterns', 'Statistics (5)', and 'Visualization'. The 'Statistics (5)' tab is active, showing a table with 5 events. The table has columns for '_time', 'host', 'Source_Address', 'user', and 'Share_Name'. All events are from 2026-03-06 and involve the user 'luke.sullivan' accessing the '*\\ADMIN\$' share from the host 'THM-DEV-WS' at IP '10.5.50.12'.

_time	host	Source_Address	user	Share_Name
2026-03-06 03:53:46	THM-DEV-WS	10.5.50.12	luke.sullivan	*\\ADMIN\$
2026-03-06 03:57:48	THM-SHR-SRV	10.5.50.12	luke.sullivan	*\\ADMIN\$
2026-03-06 03:58:02	THM-SQL-SRV	10.5.50.12	luke.sullivan	*\\ADMIN\$
2026-03-06 03:59:06	THM-SQL-SRV	10.5.50.12	luke.sullivan	*\\ADMIN\$
2026-03-06 03:59:25	THM-SQL-SRV	10.5.50.12	luke.sullivan	*\\ADMIN\$

A lógica da investigação

O raciocínio que aprendi a aplicar segue quatro estágios encadeados, partindo do destino e caminhando de volta até quem estava efetivamente no teclado.

1. Identificar o acesso — Evento 5140

```
index=win EventCode=5140 Share_Name IN ("*\\ADMIN$*", "*\\C$*")
| table _time, host, Source_Address, user, Share_Name
| sort _time
```

O que me chamou atenção é que o Evento 5140 entrega praticamente toda a informação necessária em um único registro:

- `host` — qual servidor foi alvo
- `Source_Address` — de onde partiu a conexão
- `user` — quais credenciais foram usadas
- `Share_Name` — qual compartilhamento administrativo foi acessado

O padrão que caracteriza movimentação lateral é claro: **um único IP de origem acessando ADMIN\$ em vários servidores e estações de trabalho diferentes**, especialmente quando essa origem não é uma máquina que costuma fazer esse tipo de acesso.

2. Estabelecer a linha de base

Aqui está o conceito que considero central de toda a atividade: **um evento isolado não prova nada — o que prova é o desvio do comportamento habitual**. Por isso, antes de classificar o acesso como malicioso, é necessário comparar com o histórico do próprio usuário:

```
index=win EventCode=5140 user={USER_ACCOUNT}
| table _time, Source_Address, Share_Name, host
| sort _time
```

Na investigação, a linha de base mostrou que se tratava de um usuário de TI que normalmente acessava apenas o compartilhamento de TI, sempre a partir da sua própria estação (THM-IT-DESK, IP 10.5.50.10). O contraste com o comportamento observado — múltiplos ADMIN\$ em máquinas distintas, em curto intervalo, vindos de um IP não associado a esse usuário — é o que transforma um evento comum em um indicador forte de atividade maliciosa.

```
1 index=win EventCode=5140 user=luke.sullivan
2 | table _time, Source_Address, Share_Name, host
3 | sort _time
```

All time

✓ 14 events (before 9/21/26 6:22:17.000 PM) No Event Sampling

Job Visualization

Events Patterns Statistics (14) Visualization

Show: 20 Per Page Format Preview: On

_time	Source_Address	Share_Name	host
2026-03-05 20:52:39	10.5.50.10	*\IPC\$	THM-SHR-SRV
2026-03-05 20:52:41	10.5.50.10	*\IT	THM-SHR-SRV
2026-03-05 20:53:02	10.5.50.10	*\IPC\$	THM-SHR-SRV
2026-03-05 20:53:48	10.5.50.10	*\IPC\$	THM-SHR-SRV
2026-03-06 03:53:46	10.5.50.12	*\ADMIN\$	THM-DEV-WS
2026-03-06 03:57:48	10.5.50.12	*\ADMIN\$	THM-SHR-SRV
2026-03-06 03:58:02	10.5.50.12	*\ADMIN\$	THM-SQL-SRV
2026-03-06 03:59:06	10.5.50.12	*\ADMIN\$	THM-SQL-SRV
2026-03-06 03:59:07	10.5.50.12	*\IPC\$	THM-SQL-SRV
2026-03-06 03:59:25	10.5.50.12	*\IPC\$	THM-SQL-SRV
2026-03-06 03:59:25	10.5.50.12	*\ADMIN\$	THM-SQL-SRV
2026-03-06 04:27:13	10.5.50.10	*\IT	THM-SHR-SRV
2026-03-06 04:27:13	10.5.50.10	*\IPC\$	THM-SHR-SRV
2026-03-06 04:27:36	10.5.50.10	*\IPC\$	THM-SHR-SRV

3. Traduzir o IP em nome de host — Evento 4624

Um detalhe que achei especialmente útil: no Active Directory, **todo computador possui uma conta de máquina que corresponde ao seu hostname e termina com \$**. Isso permite mapear qualquer IP para o nome do host correspondente:

```
index=win EventCode=4624 Source_Network_Address={SOURCE_IP} user=*$
```

```
| stats count by user, Source_Network_Address  
| sort -count
```

Basta remover o sufixo `$` do resultado para obter o nome do host de origem e direcionar as próximas consultas.

4. Identificar quem estava no teclado — Sysmon Evento 1

Esse foi o ponto de virada da investigação. As credenciais de um administrador de TI estavam sendo utilizadas a partir de uma estação de marketing — uma máquina onde esse usuário não teria motivo algum para estar logado. A conclusão lógica é que alguém naquela estação obteve e está reutilizando essas credenciais.

```
index=win EventCode=1 host={SOURCE_HOST} CommandLine="*ADMIN$*"
| table _time, User, Image, CommandLine
| sort _time
```

_time ↕	User ↕	Image ↕	CommandLine ↕
2026-03-06 03:53:13	NOT_TRANSLATED tryhatmestudios\michelle.smith	C:\Windows\System32\net.exe	net use \\THM-SHR-SRV\ADMIN\$ /user:TRYHATMESTUDIOS\luke.sullivan P@ssw0rd!123
2026-03-06 03:53:28	NOT_TRANSLATED tryhatmestudios\michelle.smith	C:\Windows\System32\net.exe	net use \\THM-SQL-SRV\ADMIN\$ /user:TRYHATMESTUDIOS\luke.sullivan P@ssw0rd!123
2026-03-06 03:53:46	NOT_TRANSLATED tryhatmestudios\michelle.smith	C:\Windows\System32\net.exe	net use \\THM-DEV-WS\ADMIN\$ /user:TRYHATMESTUDIOS\luke.sullivan P@ssw0rd!123

O resultado deixa evidente a separação entre dois elementos distintos:

- O campo **User** mostra **quem executou o comando** (quem estava fisicamente na máquina)
- O campo **CommandLine** mostra **quais credenciais foram usadas** (a conta comprometida)

Serem contas diferentes é, por si só, o indicador-chave de **uso indevido de credenciais**.

Complementarmente, o **Evento 4648** na máquina de origem registra um evento correspondente para cada conexão realizada, confirmando o uso das mesmas credenciais alternativas contra cada servidor de destino. É exatamente a contraparte, do lado da origem, dos Eventos 5140 encontrados nos destinos.

Limitação importante que precisei registrar

O comando `net use` é apenas **uma** das formas de acessar compartilhamentos administrativos. Frameworks de C2 como **Cobalt Strike** e **Metasploit** possuem módulos SMB integrados que se conectam sem invocar o `net.exe` — ou seja, **não geram Evento 1 do Sysmon**.

Nesses casos, a detecção não se perde, mas muda de fonte:

- O **Evento 4648** na origem ainda revela quais credenciais foram usadas e quais servidores foram alvo;

- O **Evento 5140** no destino continua sendo gerado, independentemente de como a conexão foi estabelecida.

Isso reforça algo que venho notando ao longo do estudo: depender de uma única fonte de log é frágil — a correlação entre múltiplos eventos é o que sustenta a investigação.

Questões Respondidas

Qual conta foi usada para acessar os compartilhamentos ADMIN\$?

`luke.sullivan` — identificada no campo `user` dos Eventos 5140, e confirmada como a credencial presente na `CommandLine` dos comandos executados na origem.

O que foi realizado

Nesta etapa aprofundi o entendimento de como a movimentação lateral via **SMB** se manifesta nos logs e de como reconstruir a cadeia do ataque partindo do destino até a origem.

Compreendi o papel dos **compartilhamentos administrativos** (`C$`, `ADMIN$`, `IPC$`) e, principalmente, por que seu acesso é tão relevante do ponto de vista defensivo: são recursos que usuários comuns simplesmente não utilizam, o que os torna um sinal de alto valor para detecção.

Os principais conceitos consolidados foram:

- **Evento 5140** como registro central do acesso a compartilhamentos, reunindo destino, origem, conta e recurso acessado em um único evento;
- **Análise de linha de base** como critério decisivo para separar atividade legítima de maliciosa — a ideia de que o evento isolado é neutro, e o desvio de comportamento é o que gera suspeita;
- **Mapeamento de IP para hostname** através das contas de máquina do AD (terminadas em `$`) nos Eventos 4624;
- **Sysmon Evento 1** para revelar a divergência entre o usuário que executa o comando e a credencial utilizada — indicador direto de uso indevido de credenciais;
- **Evento 4648** como confirmação, do lado da origem, do uso de credenciais explícitas contra cada alvo.

Por fim, entendi por que a correlação entre fontes de log é indispensável: ferramentas ofensivas modernas conseguem evitar artefatos de criação de processo, mas dificilmente eliminam todos os rastros simultaneamente nos lados de origem e destino. É essa redundância entre eventos que permite ao analista reconstruir o caminho do invasor mesmo quando parte da evidência não existe.

Detecção de Movimentação Lateral via PsExec

Do acesso bruto à execução remota

Na etapa anterior, analisei o acesso a compartilhamentos administrativos via `net use` — uma abordagem que permite copiar arquivos e navegar em diretórios remotamente, mas **não executa nada** no alvo. O PsExec muda esse cenário: é uma ferramenta da suíte Sysinternals que combina o acesso SMB aos compartilhamentos administrativos com a **instalação de um serviço do Windows** para executar comandos remotamente.

Entendi que vale a pena estudar o funcionamento interno do PsExec porque ele deixa um rastro de artefatos muito específico — mesmo quando o invasor renomeia o binário, o comportamento subjacente da ferramenta permanece o mesmo, o que sustenta grande parte da detecção.

Como o PsExec funciona internamente

Com uma sessão SMB já autenticada (via `net use`), ao executar `PsExec.exe \\target cmd.exe`, a sequência é a seguinte:

1. O PsExec se conecta ao compartilhamento `ADMIN$` do alvo via SMB.
2. Copia um binário de serviço (`PSEXESVC.exe`) para `C:\Windows` no destino.
3. Cria e inicia um novo serviço do Windows no destino (**Evento de Sistema 7045**).
4. O serviço cria *named pipes* para comunicação de `stdin/stdout/stderr` (**Sysmon Evento 17**).
5. O serviço executa o comando especificado pelo invasor.
6. Ao final da sessão, o PsExec remove o serviço e limpa o binário.



O ponto-chave que fixei aqui: o **Evento 7045** (novo serviço instalado) é o artefato de assinatura do PsExec, registrado na máquina de destino — é ele que diferencia o uso do PsExec do simples acesso a compartilhamentos SMB.

Por que o PsExec é tão usado por atacantes

O PsExec é uma ferramenta administrativa legítima, usada diariamente por equipes de TI para aplicar patches, rodar scripts e resolver problemas em máquinas remotas. Do ponto de vista de protocolo, o tráfego gerado é idêntico ao de uma administração SMB normal — a única diferença real está no **contexto**: qual conta, qual máquina de origem, em que horário e como foi utilizada.

Caso real: Wizard Spider

O grupo **Wizard Spider**, por trás dos ransomwares **Ryuk** e **Conti**, usou o PsExec extensivamente para implantação em massa. Segundo incidentes documentados pela Red Canary, o fluxo era: comprometer uma máquina, coletar credenciais com **Mimikatz** e então usar o PsExec para distribuir o ransomware a todos os servidores acessíveis em poucos minutos. Cada salto lateral criava um serviço via **ADMIN\$**, registrado pelo Evento 7045.

Investigando o PsExec: lado do destino

Identificando o serviço — Evento 7045

```
index=win EventCode=7045
```

```
| table _time, host, Service_Name, Service_File_Name, Service_Type, Service_Start_Type, Service_Account  
| sort _time
```

_time	host	Service_Name	Service_File_Name	Service_Type	Service_Start_Type	Service_Account
2026-03-06 03:59:06	THM-SQL-SRV	PSEXESVC	%SystemRoot%\PSEXESVC.exe	user mode service	demand start	LocalSystem
2026-03-06 03:59:25	THM-SQL-SRV	PSEXESVC	%SystemRoot%\PSEXESVC.exe	user mode service	demand start	LocalSystem

Na configuração padrão, o nome do serviço é **PSEXESVC** e o binário aponta para **C:\Windows\PSEXESVC.exe**. O campo **Service_Account** mostra em qual conta o serviço roda. Por padrão, o PsExec executa o comando como o usuário autenticado — mas com a flag **-s**, o serviço roda como **LocalSystem**, concedendo acesso em nível de SISTEMA no destino.

Rastreando os comandos executados

Como **PSEXESVC.exe** é o processo que gera os comandos remotos do invasor, filtro os eventos de criação de processo (Sysmon Evento 1) por **ParentImage**:

```
index=win EventCode=1 host={DESTINATION_HOST} ParentImage="*PSEXESVC*"  
| table _time, host, User, ParentImage, Image, CommandLine  
| sort _time
```

_time	host	User	ParentImage	Image	CommandLine
2026-03-06 03:59:07	THM-SQL-SRV	NOT_TRANSLATED tryhatmestudios\luke.sullivan	C:\Windows\PSEXESVC.exe	C:\Windows\System32\cmd.exe	"cmd" /c "hostname & whoami & ipconfig"
2026-03-06 03:59:25	THM-SQL-SRV	NOT_TRANSLATED tryhatmestudios\luke.sullivan	C:\Windows\PSEXESVC.exe	C:\Windows\System32\cmd.exe	"cmd" /c "net localgroup administrators"

Artefatos de pipes nomeados — Sysmon Evento 17

O PsExec usa *named pipes* para retransmitir *stdin*, *stdout* e *stderr* entre origem e destino:

```
index=win EventCode=17 Image="*PSEXESVC*"
| table _time, host, Image, PipeName
| sort _time
```

Os pipes seguem o padrão

`\PSEXESVC-<hostname>-<pid>-stdin/-stdout/-stderr`. Um detalhe importante: mesmo que o binário do PsExec seja renomeado, essa convenção de nomenclatura dos pipes geralmente permanece — a menos que o invasor modifique o código-fonte da ferramenta.

Evento 5145 — a mina de ouro do PsExec

O Evento 5145 (Detailed File Share) registra os arquivos e objetos específicos acessados através do compartilhamento, expostos no campo *Relative_Target_Name*:

```
index=win EventCode=5145 host={DESTINATION_HOST}
Relative_Target_Name="*PSEXE*"
| table _time, user, Source_Address, Share_Name, Relative_Target_Name
| sort _time
```

O detalhe mais valioso aqui: os nomes dos pipes contêm o **hostname de origem**, revelando de qual máquina o invasor estava operando — mesmo antes de correlacionar com o lado da fonte.

Observação: os Eventos 5140 e 5145 exigem que as políticas "Compartilhamento de Arquivo" e "Compartilhamento de Arquivo Detalhado" estejam habilitadas via GPO. A ausência desses eventos numa investigação não confirma que a atividade não ocorreu — pode simplesmente significar que a auditoria não está habilitada no ambiente.

Investigando o PsExec: lado da origem

Com o serviço e os comandos já identificados, o rastreamento até a origem se torna direto usando o Sysmon Evento 1 na máquina de origem:

```
index=win EventCode=1 host={SOURCE_HOST}
| search Image="*PsExec*"
| table _time, host, User, Image, CommandLine
| sort _time
```

_time ↕	host ↕ ✓	User ↕ ✓	Image ↕ ✓	CommandLine ↕ ✓
2026-03-06 03:54:31	THM-MKT-WS	NOT_TRANSLATED tryhatmestudios\luke.sullivan	C:\Tools\PsExec.exe	C:\Tools\PsExec.exe -accepteula \\THM-SQL-SRV cmd /c "hostname & whoami & ipconfig"
2026-03-06 03:54:51	THM-MKT-WS	NOT_TRANSLATED tryhatmestudios\luke.sullivan	C:\Tools\PsExec.exe	C:\Tools\PsExec.exe \\THM-SQL-SRV cmd /c "net localgroup administrators"

O campo **CommandLine** revela qual destino foi especificado e qual comando estava sendo executado remotamente. Correlacionando os artefatos de origem e destino, chego à reconstrução completa do que aconteceu.

Caçando PsExec renomeado

Um ponto que considero essencial: atacantes sabem que ferramentas de segurança procuram literalmente pelo nome **PSEXESVC**. A flag **-r** do PsExec permite definir um nome de serviço personalizado (**PsExec -r renamed_psexec \\target cmd**), e outras ferramentas — como o módulo **psexec.py** do Impacket ou o Cobalt Strike — geram nomes de serviço aleatórios por padrão.

Ainda assim, o **Evento 7045 dispara independentemente do nome do serviço**. O padrão real a ser buscado é: qualquer novo serviço com **Service_Type** = "serviço em modo de usuário" e **Service_Start_Type** = "início de demanda". Nome do serviço e binário podem mudar, mas essa assinatura de comportamento tende a se manter.

Questões Respondidas

Qual era o host de destino que o invasor tinha como alvo via PsExec? THM-SQL-SRV

Qual é o primeiro comando que o invasor executou na máquina de origem usando o PsExec?

```
C:\Tools\PsExec.exe -accepteula \\THM-SQL-SRV cmd /c "hostname & whoami & ipconfig"
```

O que foi realizado

Nesta etapa entendi em profundidade o funcionamento interno do **PsExec** e por que ele é uma das ferramentas mais usadas em movimentação lateral e implantação de ransomware — por operar sobre infraestrutura administrativa legítima (SMB + instalação de serviço), tornando o tráfego quase indistinguível de uma tarefa de TI comum.

Os principais artefatos que fixei para detecção no lado do **destino** foram:

- **Evento 7045** — assinatura de instalação de serviço, artefato central do PsExec;
- **Sysmon Evento 1** filtrado por **ParentImage=PSEXESVC** — revela os comandos executados remotamente;
- **Sysmon Evento 17** — pipes nomeados que carregam **stdin/stdout/stderr**;
- **Evento 5145** — o mais rico dos artefatos, pois expõe inclusive o hostname de origem embutido no nome do pipe.

Do lado da **origem**, o Sysmon Evento 1 filtrando pela imagem **PsExec** fecha o ciclo, permitindo correlacionar quem executou o quê, de onde e contra qual alvo.

Por fim, entendi a limitação prática de depender apenas do nome padrão **PSEXESVC**: atacantes podem renomear o serviço (via flag **-r** ou ferramentas como Impacket e Cobalt Strike), então o padrão comportamental (serviço em modo de usuário, início por demanda) é mais confiável do que o nome em si para caçar variações da técnica.

Detecção de Movimentação Lateral via RDP

O protocolo RDP (Remote Desktop Protocol) fornece ao invasor uma sessão interativa completa de área de trabalho. Diferente do PsExec ou do SMB, o RDP não deixa artefatos de caça tão óbvios: não há instalação de serviços, padrões de acesso a compartilhamentos ou processos exclusivos no destino que gritem "isto é um ataque". Por conta disso, raramente inicio uma investigação procurando diretamente por sessões RDP. Geralmente, o RDP é descoberto como mecanismo de entrega após outro evento (como comandos de descoberta) chamar a atenção.

O Artefato Central e a Autenticação em Nível de Rede (NLA)

O principal artefato para detecção de RDP no destino é o **Evento 4624** com **Logon_Type=10** (RemoteInteractive). Ele registra o nome da conta, o endereço IP de origem e o *timestamp* da sessão.

Um ponto de atenção crítico: o Windows moderno habilita a Autenticação em Nível de Rede (NLA) por padrão. Com o NLA, o usuário se autentica no nível da rede *antes* que a sessão RDP seja estabelecida. Isso gera um breve logon do Tipo 3 (Login de Rede) segundos antes do Tipo 10. Se essa sequência ocorrer a partir do mesmo IP, trata-se do prelúdio legítimo do NLA para o RDP, e não uma conexão SMB ou PsExec isolada.

Contexto de Ameaça: O grupo por trás do ransomware BlackSuit (sucessor do Royal, documentado pela CISA) depende do RDP como método primário de movimentação lateral, frequentemente combinando RDP, PsExec e SMB para transitar pelas redes e acessar diretamente Controladores de Domínio.

Tráfego RDP: Normal vs. Suspeito

A direção da conexão é o fator mais importante para classificar o tráfego RDP:

Padrão de Conexão	Típico?	Motivo
Estação de Trabalho → Servidor	Sim	É o padrão normal da equipe de TI para administrar servidores.

Estação de Trabalho → Estação de Trabalho	Raro	Usuários comuns não acessam as máquinas uns dos outros. O Helpdesk pode fazer isso, mas apenas a partir de estações designadas.
Servidor → Servidor	Suspeito	Servidores não iniciam RDP de saída por conta própria. Esse padrão sugere fortemente que alguém está dentro de uma sessão ativa naquele servidor e "saltando" para outro (exceto em ambientes que usam <i>caixas de salto/jump boxes</i>).

Metodologia de Investigação no Splunk (Encadeamento RDP)

Em vez de buscar o RDP diretamente, iniciei a investigação a partir de um alerta de comandos de descoberta (*nltest*, *net user*, etc.) executados no Controlador de Domínio (DC). O objetivo foi rastrear a cadeia de conexões de trás para frente.

Passo 1: Identificar a sessão inicial no destino

Ao analisar o **Evento 1 do Sysmon** no DC, encontrei os comandos de descoberta e extraí o campo *LogonId*. Esse ID vincula os comandos à sessão que os gerou.

Passo 2: Descobrir como o invasor alcançou o DC

Correlacionei o *LogonId* com o **Evento 4624** no próprio DC. O resultado revelou um *Logon_Type=10* (confirmando o uso de RDP) e o *Source_Network_Address* (IP de origem).

```
index=win EventCode=4624 host=THM-DC Logon_ID={LOGON_ID}
| table _time, user, Logon_Type, Source_Network_Address, Logon_ID
```

_time ↕	user ↕	Logon_Type ↕	Source_Network_Address ↕	Logon_ID ↕
2026-03-06 04:14:13	adm-luke.sullivan	10	10.5.30.120	0x3E7 0x508C55A

Passo 3: Identificar o host de origem e a conexão de saída

Utilizei o IP de origem para consultar o **Evento 4624** buscando por contas de máquina (terminadas em *\$*), o que revelou o *hostname* do servidor intermediário. Em seguida, consultei o **Evento 1 do Sysmon** nesse servidor intermediário buscando pela execução do cliente RDP (*mstsc.exe*):

```
index=win EventCode=1 host={SOURCE_SERVER} Image="*mstsc.exe*"
| table _time, User, Image, CommandLine, LogonId
| sort _time
```

Isso confirmou que o invasor iniciou uma conexão RDP de saída a partir daquele servidor em direção ao DC.

Passo 4: Rastrear a origem real (Quebrando a Cadeia RDP)

Peguei o novo `LogonId` do processo `mstsc.exe` e correlacionei com o **Evento 4624** no servidor intermediário. Isso revelou um novo IP e um usuário diferente.



Esse padrão é chamado de **Encadeamento RDP (RDP Chaining)**. O invasor comprometeu uma estação de trabalho, usou o RDP para pular para um servidor e, a partir dessa sessão, abriu *outra* conexão RDP para o Controlador de Domínio utilizando credenciais mais privilegiadas. A cada salto, o endereço IP de origem muda, ocultando a estação de trabalho original.

Evidências Extraídas

- **Pergunta:** Qual é o endereço IP de origem da sessão RDP que chegou ao Controlador de Domínio?
- **Pergunta:** Rastreando para trás através da cadeia, qual é o IP de origem original onde a cadeia RDP começou?

O que foi realizado

- **O que foi feito durante a atividade:** Investiguei uma intrusão baseada em movimentação lateral via RDP. Utilizando o Splunk como SIEM, realizei o rastreamento reverso de um ataque, partindo dos comandos de descoberta no Controlador de Domínio e "quebrando" as sessões intermediárias até encontrar a estação de trabalho original do invasor.
- **Os principais conceitos aprendidos:** O funcionamento do **Logon_Type 10** e sua interação com a Autenticação em Nível de Rede (NLA), que gera logs precursores do Tipo 3. O conceito fundamental da investigação foi o **Encadeamento RDP (RDP Chaining)**, uma tática onde invasores utilizam máquinas intermediárias para alcançar alvos sensíveis, alterando o IP de origem a cada salto.
- **Por que eles são importantes:** O RDP é uma das ferramentas mais abusadas por grupos de ransomware (como o BlackSuit) devido à sua interface completa e à dificuldade de detecção em meio ao tráfego administrativo normal. Rastrear o Encadeamento RDP correlacionando os logs do Windows Security (Evento 4624)

com os logs do Sysmon (Evento 1 para o `mstsc.exe`) é mandatório. Sem essa correlação de identificadores de sessão (`LogonId`), a equipe de resposta a incidentes bloquearia apenas o servidor intermediário, deixando a estação de trabalho original (o verdadeiro ponto de comprometimento) ativa na rede.

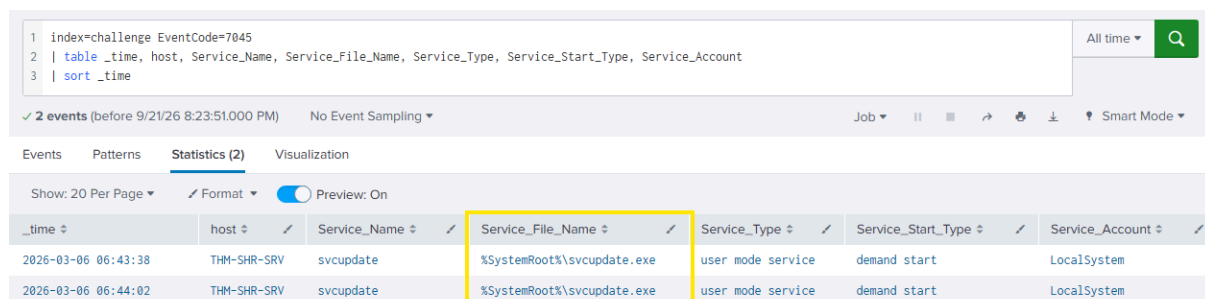
Desafio Prático: Rastreamento Reverso de Movimentação Lateral

O SOC recebeu um alerta crítico do EDR referente à instalação de um serviço anômalo nomeado `svcupdate` no servidor `THM-SHR-SRV`. Como o serviço não correspondia a nenhuma implantação de software homologada e não havia requisições de mudança agendadas (RDM) para o período, iniciei uma investigação no Splunk (utilizando o índice isolado `index=challenge`) para confirmar a intrusão e rastrear a origem do ataque.

Metodologia de Investigação

Para reconstruir o caminho do atacante, apliquei a técnica de rastreamento reverso (*backtracking*), partindo do artefato final no servidor de destino até chegar à máquina de origem:

1. **Análise do Destino (Instalação do Serviço):** O ponto de partida foi validar o alerta do EDR. Filtrei os logs de sistema no `THM-SHR-SRV` buscando pela criação de novos serviços (Evento 7045). O objetivo era isolar o serviço `svcupdate` e extrair o caminho exato onde o invasor ocultou o binário malicioso no disco.



The screenshot shows a Splunk search interface with the following search query and results:

```
1 index=challenge EventCode=7045
2 | table _time, host, Service_Name, Service_File_Name, Service_Type, Service_Start_Type, Service_Account
3 | sort _time
```

Results (2 events):

_time	host	Service_Name	Service_File_Name	Service_Type	Service_Start_Type	Service_Account
2026-03-06 06:43:38	THM-SHR-SRV	svcupdate	%SystemRoot%\svcupdate.exe	user mode service	demand start	LocalSystem
2026-03-06 06:44:02	THM-SHR-SRV	svcupdate	%SystemRoot%\svcupdate.exe	user mode service	demand start	LocalSystem

2. **Rastreamento de Acesso e Credenciais (O Vetor de Entrega):** Sabendo que um binário foi depositado remotamente, a etapa seguinte foi descobrir *como* ele chegou lá. Analisei os logs de acesso a compartilhamentos de rede (Evento 5140), focando especificamente no compartilhamento administrativo `ADMIN$`. Isso permitiu descobrir qual conta de usuário foi indevidamente utilizada para estabelecer a

conexão SMB inicial.

The screenshot shows a Splunk search interface with the following query: `1 index=win EventCode=5140 Share_Name IN ("*\\ADMIN$*", "*\\C$\\*") 2 | table _time, host, Source_Address, user, Share_Name 3 | sort _time`. The results table has 5 columns: `_time`, `host`, `Source_Address`, `user`, and `Share_Name`. The `Source_Address` column is highlighted with a yellow box. All entries show the IP address 10.5.50.12.

_time	host	Source_Address	user	Share_Name
2026-03-06 03:53:46	THM-DEV-WS	10.5.50.12	luke.sullivan	*\ADMIN\$
2026-03-06 03:57:48	THM-SHR-SRV	10.5.50.12	luke.sullivan	*\ADMIN\$
2026-03-06 03:58:02	THM-SQL-SRV	10.5.50.12	luke.sullivan	*\ADMIN\$
2026-03-06 03:59:06	THM-SQL-SRV	10.5.50.12	luke.sullivan	*\ADMIN\$
2026-03-06 03:59:25	THM-SQL-SRV	10.5.50.12	luke.sullivan	*\ADMIN\$

3. **Correlação de Origem (Do IP ao Hostname):** Com o endereço IP do atacante em mãos (extraído da conexão SMB), cruzei essa informação com os logs de logon (Evento 4624) buscando por contas de máquina (terminadas em \$). Isso traduziu o IP de origem para o nome exato do host (hostname) de onde o invasor estava operando.

The screenshot shows a Splunk search interface with the following query: `1 index=challenge EventCode=4624 Source_Network_Address=10.5.50.15 user==$ 2 | stats count by user, Source_Network_Address 3 | sort -count`. The results table has 3 columns: `user`, `Source_Network_Address`, and `count`. The `user` column is highlighted with a yellow box, showing the value THM-HR-WS\$.

user	Source_Network_Address	count
THM-HR-WS\$	10.5.50.15	30

4. **Identificação da Execução Remota (Comandos Iniciais):** Para entender o impacto total, utilizei os dados mapeados para filtrar os eventos de criação de processos (Evento 1 do Sysmon). O foco foi extrair a linha de comando exata (CommandLine) que o atacante executou na máquina de origem para disparar a movimentação lateral contra o alvo.

The screenshot shows a Splunk search interface with the following query: `1 index=challenge EventCode=1 host=THM-SHR-SRV ParentImage="*svcupdate*" 2 | table _time, host, User, ParentImage, Image, CommandLine 3 | sort _time`. The results table has 6 columns: `_time`, `host`, `User`, `ParentImage`, `Image`, and `CommandLine`. The `CommandLine` column is highlighted with a yellow box, showing the command `"cmd" /c "hostname & whoami & ipconfig"`.

_time	host	User	ParentImage	Image	CommandLine
2026-03-06 06:43:39	THM-SHR-SRV	NOT_TRANSLATED tryhatmestudios\ryan.chen	C:\Windows\svcupdate.exe	C:\Windows\System32\cmd.exe	"cmd" /c "hostname & whoami & ipconfig"
2026-03-06 06:44:03	THM-SHR-SRV	NOT_TRANSLATED tryhatmestudios\ryan.chen	C:\Windows\svcupdate.exe	C:\Windows\System32\cmd.exe	"cmd" /c "net localgroup administrators"

Evidências Extraídas

- **Pergunta:** Qual é o caminho completo do binário de serviço que foi instalado no destino (THM-SHR-SRV)?
 - **Resposta:** %SystemRoot%\svcupdate.exe
 - **Explicação:** Extraído do campo `Service_File_Name` no Evento de Sistema 7045.
- **Pergunta:** Qual conta foi usada para acessar o compartilhamento ADMIN\$ no servidor de destino?

- **Resposta:** ryan.chen
- **Explicação:** Identificada através do cruzamento de logs do Evento 5140 (Detailed File Share) e 4624 (Logon).
- **Pergunta:** Qual é o endereço IP de origem do movimento lateral para THM-SHR-SRV?
 - **Resposta:** 10.5.50.15
 - **Explicação:** Obtido ao rastrear o IP que iniciou a requisição de acesso ao compartilhamento administrativo.
- **Pergunta:** Qual é o primeiro comando remoto que o invasor executou na máquina de laboratório?
 - **Resposta:** "cmd" /c "hostname & whoami & ipconfig"
 - **Explicação:** Localizado no campo **CommandLine** do Evento 1 do Sysmon, vinculando a ação à conexão mapeada.
- **Pergunta:** De qual host o ataque se originou?
 - **Resposta:** THM-HR-WS
 - **Explicação:** Validado correlacionando o endereço IP de origem com as autenticações de conta de máquina no Active Directory.

O que foi realizado

- **O que foi feito durante a atividade:** Conduzi a investigação autônoma de um incidente real acionado por um EDR. Realizei o rastreamento reverso de uma movimentação lateral, conectando a instalação de um serviço anômalo (**svcupdate**) no destino até o host e a conta de origem utilizados pelo invasor.
- **Os principais conceitos aprendidos:** A aplicação prática da correlação avançada de eventos em um **SIEM** (Splunk). Estruturei a investigação encadeando artefatos de TTPs comuns (Táticas, Técnicas e Procedimentos): acesso a compartilhamentos administrativos ocultos (**ADMIN\$**), instalação de serviços maliciosos e execução remota de processos.
- **Por que eles são importantes:** Em um SOC, incidentes frequentemente começam com um único alerta isolado no destino final. A habilidade de interpretar **logs** para executar o *backtracking* da cadeia de ataque é o que permite à equipe de resposta a incidentes (IR) dimensionar corretamente a violação, isolando não apenas o servidor atacado, mas a máquina de origem — o verdadeiro "Paciente Zero" — antes que o invasor alcance ativos mais críticos.